

Incident Response Engagement Findings & Detection Report

Mission 01 - Network Recon & First Shell

CLIENT

NexaCorp

Internal server intrusion investigation

Engagement reference INC-2026-001

Phase 1: forensic analysis · Phase 2: detection engineering

Prepared by

Johan-Emmanuel Hatchi

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 11 May 2026

Plain-Language Summary

For NexaCorp IT management: non-technical overview.

On the evening of **9 May 2026 around 22:53 UTC**, an external attacker compromised one of your internal servers (192.168.10.10) by exploiting a **2011-vintage vulnerability** in an outdated FTP service. They obtained administrator-level access for about 20 seconds, looked around to map the system, then left. They did not steal data, install permanent access, or move to other servers through this entry point.

However, our investigation revealed a **separate and more concerning issue**: the same server was **already infected** before this attack, running a hidden remote-control program (MITRE Caldera) that has been quietly contacting an external system every minute. This is the 'unusual outbound connection' your IT team flagged. We do not know when or how this earlier infection started, it predates the network capture you provided.

Your monitoring system (Wazuh SIEM) recorded **397 events** during this incident, but **only 4 were classified as high-priority**, and **none of them identified the actual attack or the hidden remote-control program**. In a busy security team, those 4 alerts would have been dismissed as routine background noise.

Immediate actions required: disconnect and forensically image the affected server, decommission the outdated FTP service, and reconfigure your firewall to alert on (not just log) outbound connections to unknown destinations. Detailed findings, evidence, and a full remediation plan follow.

Table of Contents

PLAIN-LANGUAGE SUMMARY	2
CONFIDENTIALITY STATEMENT	5
DISCLAIMER	5
EXECUTIVE SUMMARY	6
A. Introduction	6
B. Scope	6
C. Engagement summary	7
D. Overview of findings	9
E. Overview of recommendations	10
METHODOLOGY	11
A. Procedure	11
B. Severity Ratings	13
ATTACK TIMELINE	14
INDICATORS OF COMPROMISE (IOCs)	15
A. Network indicators	15
B. Payload and behavioural signatures	15
C. Host artifacts	16
D. Wazuh rule IDs	16
E. STIX / OpenIOC export note	16
INVESTIGATION TECHNICAL SUMMARY	17
I1. vsftpd 2.3.4 vulnerable service exposed	17
I2. Extended low-and-slow reconnaissance phase	19
I3. CVE-2011-2523 exploitation (USER smiley)	21
I4. Unauthenticated root bind shell on TCP/6200	23
I5. Pre-existing MITRE Caldera Sandcat C2 implant	25
I6. Multi-protocol service enumeration	28
I7. SSH brute-force attempts (Wazuh)	30
I8. Anomalous sudo activity	32
I9. Insufficient SIEM detection coverage	34
I10. Host audit log gap	36
DETECTION ENGINEERING (PHASE 2)	38
A. Methodology	38
B. Rule catalog (R1-R7): full rule text	38
C. Validation results	44
D. Tuning notes & lessons learned	45
E. False-positive analysis	46
F. Evasion considerations	46
G. Beyond-detection recommendations	47
RISK MATRIX	49

MITRE ATT&CK MAPPING	50
TOOLS AND STANDARDS	51
A. Tools Used	51
B. Standards and Frameworks Followed	52
GLOSSARY AND ACRONYMS	53

Confidentiality Statement

This report documents **Mission 01** of the BeCode Corp internal cybersecurity training programme. The engagement was conducted against a controlled laboratory environment simulating an internal network intrusion at the fictitious organisation *NexaCorp*. The target host was a virtual instance of *Metasploitable 2* (a deliberately vulnerable Linux distribution maintained by Rapid7 for training purposes), deployed in the BeCode SOC lab under reference BCC-2026.

No real production system, customer data, or third-party infrastructure was targeted, accessed, or affected by this engagement. All IP addresses, hostnames, and accounts referenced in this report belong to the BeCode training environment and have no production analogue.

This document is classified as **Internal - Not for distribution** under reference **BCC-2026 | INC-2026-001**. It is intended for the BeCode Corp training coordination team, the assigned mentors, and the auditor. Any redistribution outside this scope requires explicit authorization.

Subject to the above, the auditor retains the right to share this report as part of professional portfolios, certification evidence, and job applications, in line with the BeCode Corp policy on training deliverables.

Disclaimer

The findings and recommendations in this report are based on a specific snapshot of the BeCode SOC lab environment between **9 May 2026 and 11 May 2026**. The reported window corresponds to the network capture provided by the simulated client (5h31m of PCAP from May 9 20:08 UTC to May 10 01:39 UTC) augmented by Wazuh SIEM event ingestion (397 events for the affected agent) and host log snapshots from the compromised system.

The engagement spanned three days (9 May - 11 May 2026) with approximately 7 hours of active investigation across multiple sessions. This window allowed end-to-end reconstruction of the captured intrusion, but the evidence package provided by the simulated client has limitations that bound the depth of certain findings. In particular, the host audit logs do not cover the incident window, and the network capture starts after an initial compromise that installed the C2 implant documented in finding I5.

This report focuses on findings representative of common SOC L1 / L2 analyst workloads, applying the methodology recommended by **NIST SP 800-61r2** (Computer Security Incident Handling Guide) and the **SANS PICERL** incident response process.

Executive Summary

A. Introduction

This document reports on an internal training engagement aimed at evaluating the auditor's ability to investigate, characterise, and document a network intrusion under conditions approximating a real SOC analyst engagement. A fictitious client, *NexaCorp*, reported anomalous outbound traffic from one of their internal servers; the BeCode SOC team was tasked with determining the nature, scope, and impact of the suspected compromise.

The engagement was designed to simulate a real-world incident response workflow: ingest an evidence package provided by the client (network capture + host logs + SIEM exports), reconstruct the attack chain end-to-end, correlate signals across multiple detection layers (firewall, host, SIEM, network), identify gaps in existing detection coverage, and produce a remediation roadmap. A second phase added detection engineering deliverables: a set of Suricata IDS rules validated by offline PCAP replay.

The primary objective was methodological rigour: each finding documented in this report was traced from at least two independent evidence sources, validated against the captured packet timestamps, and cross-referenced with the SIEM ingestion. The detection rules delivered in Phase 2 were validated by full PCAP replay against a live Suricata instance and produced the expected alerts for every identified attack stage.

B. Scope

Assessment	Details
Network intrusion investigation + detection engineering 9 May 2026 - 11 May 2026 Approximately 7 hours active investigation across multiple sessions Evidence-driven reconstruction (white-box on SIEM, black-box on target)	What was investigated: - Target host: 192.168.10.10 (Metasploitable 2, hostname metasploitable, Linux 2.6.24) - Application stack: vsftpd 2.3.4, OpenSSH 4.7p1, Apache, Postfix, MySQL, Tomcat - Threat actor (network): 172.16.50.10 · C2 endpoint: 10.40.0.200:8888 (Caldera Sandcat) - SIEM platform: Wazuh 4.x, agent 020 (blue11, 192.168.100.60) - In scope: PCAP analysis, host log review, SIEM correlation, NIDS detection engineering - Out of scope: live forensic acquisition, malware reverse engineering, threat actor attribution

C. Engagement summary

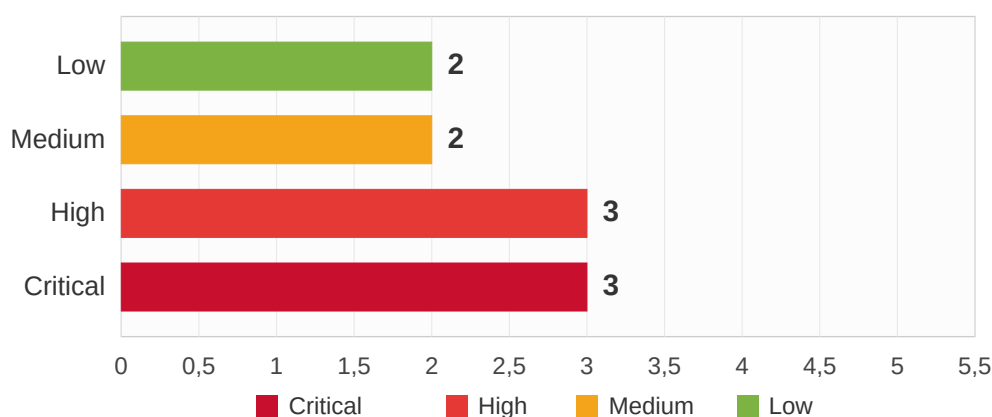
The investigation reconstructed a textbook **opportunistic external intrusion** performed against a publicly-reachable vulnerable service (vsftpd 2.3.4, CVE-2011-2523). The attack chain comprises a 15-hour low-and-slow reconnaissance phase, a single-packet exploitation event triggering a backdoored FTP daemon, a 20-second post-exploitation session executing root-level enumeration commands, and a clean disengagement. The attack chain itself is well-documented and the artifacts captured in the PCAP are unambiguous.

However, the investigation also surfaced a **second, independent finding** of significantly higher long-term concern: the compromised host was already running an active **MITRE Caldera Sandcat** command-and-control agent before the captured window began, beaconing to a non-NexaCorp external endpoint in cleartext HTTP. This is the 'unusual outbound connection' originally flagged by the NexaCorp IT team, and it indicates a prior compromise whose origin is not represented in the evidence package. The two incidents involve different attacker IPs and likely different threat actors.

Analysis of the NexaCorp Wazuh SIEM confirms that the attack was **largely invisible to existing monitoring**: of 397 events ingested from the affected host, **88.4% were classified as low-severity informational (level 3)**, only **4 events (1.0%) reached high severity (level 10)**, and the four high-severity alerts identified the brute-force fingerprint of the attack without surfacing the actual CVE-2011-2523 exploitation, the post-exploit shell, or the Caldera C2 channel. In a normal SOC queue, those four alerts would have been dismissed as routine brute-force noise.

The overall security posture of the affected NexaCorp segment is rated **CRITICAL**. The combination of a 2011-vintage backdoored service still running in production, a SIEM configured for generic brute-force detection but not for known-CVE exploitation patterns, a pre-existing C2 implant, and an evidence chain with significant logging gaps points to systemic weaknesses in asset inventory, patch management, network egress control, and detection engineering.

Vulnerabilities by Severity Level

**B.**

Three findings reach Critical severity: the running of vsftpd 2.3.4 with its publicly-documented unauthenticated remote code execution backdoor (I1), the unauthenticated root shell obtained through exploitation of that backdoor (I4), and the pre-existing Caldera C2 implant indicating prior compromise (I5).

The assessment also identified **three High-severity findings** related to detection failure and post-exploit indicators (I3 the exploitation event itself, I8 anomalous first-time-sudo activity suggesting potential further compromise, and I9 the insufficient SIEM detection coverage), **two Medium-severity findings** (I2 the extended reconnaissance phase, and I7 SSH brute-force attempts visible only through SIEM logs), and **two Low-severity findings** (I6 multi-protocol enumeration, and I10 the host audit log gap).

In conclusion, the volume and severity of findings render the affected segment unsuitable for continued operation without comprehensive remediation. Acting on the recommendations presented in this report would meaningfully strengthen the cybersecurity posture, reduce time-to-detect for similar incidents, and bring NexaCorp's detection engineering practice closer to industry standard.

D. Overview of findings

This list provides the general overview of all findings documented in this report. In the reference, the 'I' before the figure stands for *Investigation* (incident response context).

Ref	Description	Severity
I1	vsftpd 2.3.4 vulnerable service exposed on the internal network (CVE-2011-2523)	CRITICAL
I2	Extended 15-hour low-and-slow reconnaissance phase preceding the exploit	MEDIUM
I3	CVE-2011-2523 exploitation via USER baduser:) backdoor trigger	HIGH
I4	Unauthenticated root bind shell obtained on TCP/6200, 8 enumeration commands	CRITICAL
I5	Pre-existing MITRE Caldera Sandcat C2 implant, daemonised as root with active	CRITICAL
I6	Multi-protocol service enumeration (HTTP/SSH/SMTP/Telnet/MySQL banner grab)	LOW
I7	SSH brute-force attempts visible in Wazuh, outside PCAP capture window	MEDIUM
I8	Anomalous sudo activity including two 'first time user executed sudo' events	HIGH
I9	Insufficient Wazuh SIEM detection coverage (4 high alerts among 397 events; 88	HIGH
I10	Host audit logs do not cover the incident window	LOW

E. Overview of recommendations

This list is a short overview of the proposed recommendations by finding. Detailed recommendations are provided alongside each finding in the Investigation Technical Summary.

REF	VULNERABILITY	SHORT RECOMMENDATION
I1	vsftpd 2.3.4 exposed	Decommission or upgrade vsftpd to a current build ($\geq 3.0.x$). Migrate to OpenSSH/SFTP if FTP is not strictly required. Add the vsftpd 2.3.4 banner to the asset inventory ban-list. Schedule monthly vulnerability scans against the internal segment.
I2	Slow-paced reconnaissance	Deploy a network IDS (Suricata) on the segment ingress. Add SIEM correlation rules that aggregate FTP/SSH/HTTP recon signals from the same source IP across a 6-hour window with a low per-signal threshold.
I3	Exploitation event	Deploy Suricata rule R1 (CVE-2011-2523 USER smiley signature) on the segment ingress. Concurrent: remediate I1 (the rule becomes redundant once the vulnerable service is removed).
I4	Root bind shell	Deploy Suricata rule R3 (inbound TCP/6200 detection) and add port 6200 to the firewall deny-list. Take the affected host offline and conduct a full forensic acquisition (disk + memory image).
I5	Caldera C2 implant	P0 - IMMEDIATE. Quarantine the host. Acquire memory and disk images before any cleanup. Investigate /opt/caldera/sandcat (PID 4749, parent PID 1). Enumerate persistence and any tasks issued through the C2 channel. Implement an egress allowlist policy.
I6	Multi-protocol recon	Disable unused services on internal hosts (Telnet, externally-exposed MySQL, phpMyAdmin if not actively used). Implement service banner suppression at the application layer where supported.
I7	SSH brute-force	Enforce PubkeyAuthentication only (disable password auth) for any internet-reachable SSH endpoint. Configure fail2ban or equivalent. Verify Wazuh rule 5551 (level 10) is escalated to immediate notification.
I8	Anomalous sudo activity	Pull the full_log field for all 80 sudo events identified in this investigation. Correlate timestamps with the FTP exploitation event. Review user accounts with newly-acquired sudo privileges. Configure auditd execve monitoring on critical hosts.
I9	SIEM detection gap	Author Wazuh correlation rules combining existing brute-force signals (rules 11452, 5551, 5503) with first-time-sudo events (rule 5403) within a short time window to elevate severity automatically. Deploy the seven Suricata rules delivered with this engagement.
I10	Host log gap	Enable extended log retention (90 days minimum) and ship logs off-host in near-real-time to the central SIEM. The current configuration lost the logs covering the incident window.

Methodology

A. Procedure

As a base for this analysis, we use industry-standard incident-response frameworks and customized investigative workflows tailored to the SOC environment. Our methodology aligns closely with the **NIST SP 800-61 Rev. 2** (Computer Security Incident Handling Guide) and the **SANS PICERL** process (*Preparation, Identification, Containment, Eradication, Recovery, Lessons learned*). The first step involves ingesting the evidence package and triaging it for completeness. Secondly, we reconstruct the network-level attack chain from the packet capture. In the third phase, we correlate network events with host and SIEM logs to identify gaps and corroborating evidence. Then we characterise the impact and assess the existing detection coverage. In the final step, we consolidate all findings in this technical report, formulate recommendations, and deliver a detection engineering ruleset addressing the identified gaps.

In general, our assessment includes the following phases:

01. Scope & Pre-engagement

- Receive and validate the evidence package (PCAP, host logs, SIEM exports)
- Confirm engagement boundaries with the simulated client
- Setup investigation workstation (Wireshark, tshark, Wazuh dashboard access, Suricata)



02. Network attack reconstruction

- High-level PCAP triage: protocol breakdown, conversation list, time window
- Per-flow analysis of suspect conversations (TCP stream follow, manual payload review)
- Service fingerprinting from server banners
- Identification of exploit signatures and post-exploit traffic patterns



03. Multi-source correlation

- Host log review (auth.log, syslog) cross-referenced against PCAP timeline
- Wazuh SIEM event extraction (filter: location: *nexacorp* AND agent.id: 020)
- Severity distribution analysis (CSV export of 397 events, statistical breakdown by rule.level)
- Indicator of compromise consolidation across all sources



04. Detection gap analysis

- Inventory of what each detection layer (firewall / host / SIEM / NIDS) caught
- Identification of structural blind spots (vsftpd does not log its own exploitation; no NIDS deployed)
- Mapping each finding to MITRE ATT&CK techniques to enable downstream threat hunting



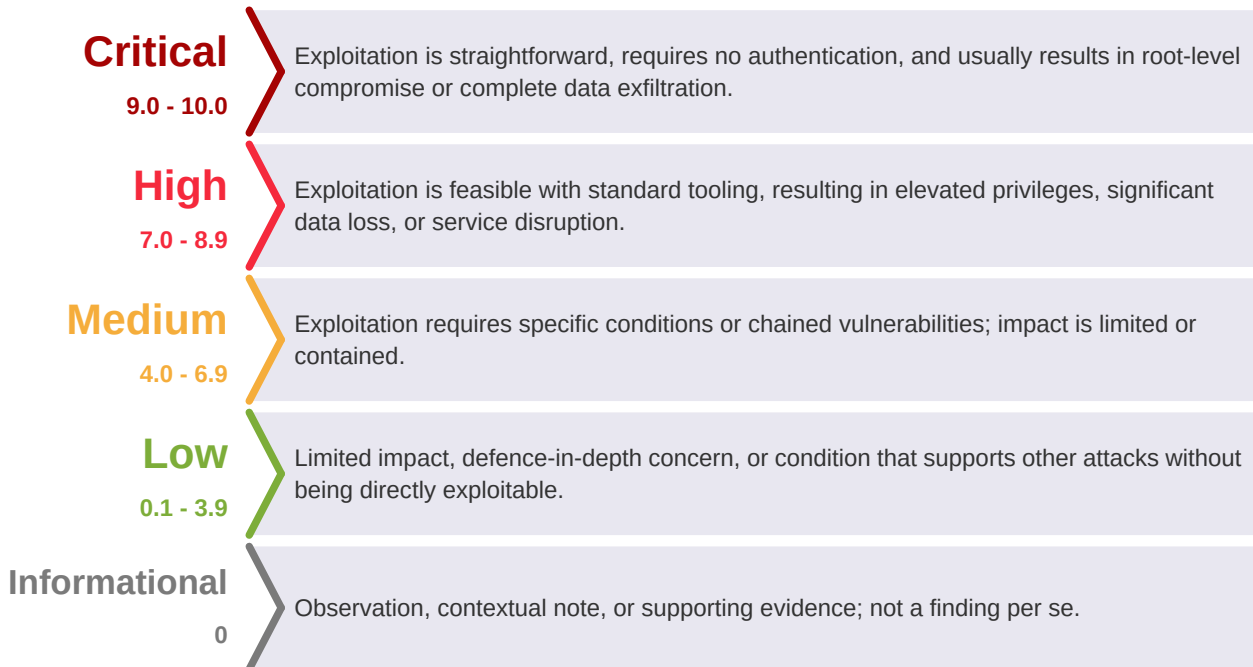
05. Detection engineering & reporting

- Authoring of seven Suricata rules covering the identified attack stages
- Validation via offline PCAP replay (tcpdump) against a live Suricata 6.0.4 instance
- Tuning iterations to address rule warnings, HOME_NET overlap, HTTP parser binding
- Consolidation of findings into this technical report; CVSS-derived severity classification



B. Severity Ratings

We assess the risk level of findings by using the **CVSS v3.1** score as the foundation, enhanced with a contextual likelihood factor to reflect operational ease of exploitation.



Base score metrics follow CVSS v3.1 specification: Attack Vector (AV), Attack Complexity (AC), Privileges Required (PR), User Interaction (UI), Scope (S), Confidentiality / Integrity / Availability impact (C/I/A). The complete vector string is provided for each finding.

Likelihood considerations applied on top of the base CVSS include: whether authentication is required, the attacker's network position (internet / adjacent / local), the exploitation complexity (PoC available vs. no guidance), and any special conditions required. A finding's final severity reflects both the CVSS base score and the practical exploitability in NexaCorp's specific environment.

Attack Timeline

All timestamps in UTC. Sources: [P] = PCAP, [W] = Wazuh SIEM, [H] = Host logs.

#	Timestamp	Src	Event
01	May 9 07:48	[W]	First FTP connection from 172.16.50.10 visible in Wazuh - attacker began recon ~15h before exploit
02	May 9 13:23 - 19:05	[W]	Continued slow-paced FTP reconnaissance, cadence 20-90 min between connections
03	May 9 19:05:38	[W]	Wazuh rule 11452 threshold crossed (12 FTP connects in 60s) - level 10 alert would have fired
04	May 9 20:08:30	[P]	PCAP starts. Caldera Sandcat agent already actively beaconing to 10.40.0.200:8888
05	May 9 20:10:48	[P]	First HTTP reconnaissance from 172.16.50.10: GET /
06	May 9 20:12:36	[P]	First FTP connection in PCAP - server returns banner 220 (vsFTPD 2.3.4)
07	May 9 20:12:37	[P]	First content-mapping recon: USER anonymous + PASS guest@ + LIST + QUIT
08	May 9 20:30:20	[P]	First username enumeration: USER ftpuser + PASS wrongpassword
09	May 9 20:54:34	[P]	Telnet banner grab on TCP/23
10	May 9 20:54:49	[P]	SMTP banner grab on TCP/25
11	May 9 21:21:53	[P]	HTTP recon: GET /admin
12	May 9 21:22:44	[P]	HTTP recon: GET /login
13	May 9 21:30:00	[P]	SSH banner grab: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
14	May 9 21:55:54	[P]	HTTP recon: GET /phpmyadmin
15	May 9 ~21:00-22:00	[W]	PAM brute-force burst triggers rule 5551 (level 10): 8+ failed PAM auth in 120s
16	May 9 22:53:31	[P]	EXPLOIT: USER baduser:) sent - CVE-2011-2523 backdoor triggered
17	May 9 22:53:32	[P]	PASS anything sent - FTP flow terminates without QUIT
18	May 9 22:53:35	[P]	Bind shell on TCP/6200 opened, attacker connects
19	May 9 22:53:36	[P]	Shell command: id -> uid=0(root)
20	May 9 22:53:38	[P]	Shell command: whoami -> root
21	May 9 22:53:40	[P]	Shell command: uname -a -> Linux metasploitable 2.6.24-16-server
22	May 9 22:53:42	[P]	Shell command: hostname -> metasploitable
23	May 9 22:53:45	[P]	Shell command: cat /etc/passwd head -10
24	May 9 22:53:48	[P]	Shell command: ls /home -> ftp / msfadmin / service / user
25	May 9 22:53:51	[P]	Shell command: ifconfig -> reveals MAC bc:24:11:98:04:3f (Proxmox OUI)
26	May 9 22:53:54	[P]	Shell command: netstat -an grep LISTEN -> enumerates 22 listening services
27	May 9 ~22:53:55	[P]	Bind shell closes (~20s total session). No persistence, no exfiltration
28	May 9 23:05 - May 10 01:13	[P]	6 additional FTP recon attempts post-exploit (cleanup / verification)
29	May 10 01:39:03	[P]	End of PCAP capture (frame 5,194)
30	May 10 06:37:10	[H]	First post-incident syslog entry: syslogd restart (likely VM reboot)
31	May 10 08:47:22	[H]	First post-incident SSH login: msfadmin from 192.168.10.1
32	May 11 11:39	[W]	Wazuh log ingestion pipeline restored (coach confirmation)
33	May 11 13:17-13:28	[W]	Bulk ingestion of 397 NexaCorp events; 4 retrospective level-10 alerts triggered

The Caldera Sandcat implant (item 04) **predates the entire captured window**, indicating the initial compromise that installed it occurred before May 9 20:08 UTC and is not represented in the evidence package.

Indicators of Compromise (IOCs)

The following indicators were extracted from the evidence package and consolidated here for direct ingestion into NexaCorp's SIEM, threat intelligence platform, or firewall rule sets. Each indicator is annotated with its source (PCAP / Wazuh / decoded payload) and the finding it relates to.

A. Network indicators

Type	Value	Context	Source	Finding
IPv4 (source)	172.16.50.10	External attacker: vsftpd exploit, multi-protocol recon, SSH brute-force	PCAP + Wazuh	I2, I3, I4, I6, I7
IPv4 (target)	192.168.10.10	Compromised internal NexaCorp server	PCAP	I1-I10
IPv4 (C2 server)	10.40.0.200	MITRE Caldera C2 endpoint, external, non-NexaCorp	PCAP	I5
TCP port	21	vsftpd 2.3.4 vulnerable service	PCAP	I1
TCP port	6200	Backdoor bind shell (vsftpd 2.3.4 CVE-2011-2523)	PCAP	I4
TCP port	8888	Caldera C2 listening port (non-standard HTTP)	PCAP	I5
MAC address	bc:24:11:98:04:3f	Target host MAC (Proxmox OUI, virtualised host indicator)	PCAP	I4

B. Payload and behavioural signatures

Signature	Detection context	Source	Finding
FTP USER argument matching regex / [^] USER\s+ [\] S*:\)\r?\n/i	CVE-2011-2523 backdoor trigger pattern (smiley terminator)	PCAP	I3
FTP banner 220 (vsFTPd 2.3.4) returned by any server	Vulnerable service exposure (banner grab)	PCAP	I1
HTTP request POST /beacon with User-Agent: Go-http-client/1.1	Caldera Sandcat agent beacon (port-agnostic)	PCAP, decoded	I5
HTTP response header Server: Python/3.10 aiohttp/3.13.4	Caldera C2 server fingerprint	PCAP	I5
HTTP GET to /admin, /phpmyadmin, /login from curl or wget UA	Automated path enumeration tooling	PCAP	I6
FTP USER + PASS wrongpassword + QUIT (literal wrongpassword)	Username-enumeration probe pattern (timing-based, not credential-based)	PCAP	I2
5+ FTP CONNECT events from same source IP within 30 minutes	Low-and-slow reconnaissance cadence	Wazuh full_log	I2

C. Host artifacts (to verify on live host post-quarantine)

Type	Value	Action	Finding
File path	/opt/caldera/sandcat	Caldera agent binary: quarantine, hash, forensic image	I5
Process	PID 4749 (parent PID 1)	Implant process: capture memory before kill	I5
Caldera identifier	paw=mesdec	Agent unique ID: useful for cross-correlation if operator surfaces in other incidents	I5
Caldera operator label	group=lab-unknown	Internal operator tagging	I5
Wazuh rule	5403 (first time user executed sudo), 2 firings	Identify which user accounts triggered these, when, with what command	I8

D. Wazuh rule IDs relevant to this incident

Wazuh rule.id	Description	Level	Count	Finding
11452	vsftpd: Multiple FTP connection attempts from same source IP	10	2	I2, I9
5551	PAM: Multiple failed logins in a small period of time	10	2	I7, I9
5503	PAM: User login failed	5	16	I7
5706	sshd: insecure connection attempt (scan)	6	12	I7
5715	sshd: authentication success	3	12	I7
5402	Successful sudo to ROOT executed	3	61	I8
5407	Successful sudo executed	3	17	I8
5403	First time user executed sudo	4	2	I8
11401	vsftpd: FTP session opened	3	43	I2
11402	vsftpd: FTP Authentication success	3	14	I2
11403	vsftpd: Login failed	5	10	I2

E. STIX / OpenIOC export note

The above indicators can be exported in **STIX 2.1** format on request. The IP-based indicators (172.16.50.10, 10.40.0.200) should be added to NexaCorp's perimeter blocklist immediately and shared with relevant ISACs (FS-ISAC, MS-ISAC) if applicable to the sector.

Investigation Technical Summary

This section documents the ten findings identified during the investigation. Each finding includes the affected scope, CVSS-derived severity assessment, technical description, evidence proof, and remediation recommendation.

11. vsftpd 2.3.4 vulnerable service exposed on the internal network

Severity:

CRITICAL

Finding type:

Application-related vulnerability (vulnerable deployment)

CVSS v3.1 base score:

10.0 (Critical) - AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

CWE:

CWE-1395 (Dependency on Vulnerable Third-Party Component) - chained with CVE-2011-2523

MITRE ATT&CK:

T1190 (Exploit Public-Facing Application)

Affected scope:

- 192.168.10.10:21 (NexaCorp internal FTP server, hostname metasploitable)
-

Description:

The target host 192.168.10.10 exposes vsftpd version 2.3.4 on TCP port 21. This is the precise build distributed for approximately three days in July 2011 after the upstream vsftpd download mirror was compromised by an unknown attacker. The compromised release contains an **unauthenticated backdoor**: when any FTP client sends a USER command whose argument ends with the byte sequence :), the vsftpd daemon forks a child process that opens a listener on TCP port 6200 and binds an interactive shell with root privileges to it. No authentication is required to access this shell.

This vulnerability is catalogued as **CVE-2011-2523 (CVSS 10.0)** and has been publicly documented since July 2011. Detection signatures exist in every major IDS rule set since that date. Modern vulnerability scanners (Nessus, OpenVAS, Qualys) identify the backdoored build via banner grabbing as a Critical finding. The continued presence of this version on a NexaCorp internal system in 2026 - fifteen years after disclosure - indicates a serious gap in asset inventory, patch management, and vulnerability scanning practices.

Proof of evidence - banner exposure

The vulnerable banner is exposed in every FTP response. Extracted from attack.pcap:

```
$ tshark -r attack.pcap -Y "ftp.response.code == 220 && ip.src == 192.168.10.10" \
-T fields -e frame.time -e ftp.response.arg | head -3
May  9, 2026 20:12:36 UTC      (vsFTPd 2.3.4)
May  9, 2026 20:30:21 UTC      (vsFTPd 2.3.4)
May  9, 2026 20:54:12 UTC      (vsFTPd 2.3.4)
```

The banner is returned on every FTP connection, exposing the version to any client capable of opening a TCP socket to port 21. No authentication, payload, or special tooling is required to identify this host as vulnerable. The Shodan signature for this banner is well-known and would surface the host on any public-facing scan.

Recommendation:

- **P0 - Decommission or upgrade vsftpd 2.3.4 immediately.** Migrate to a current build ($\geq 3.0.x$) or, preferably, retire FTP in favour of SFTP / SCP over an OpenSSH endpoint.
- Add the vsftpd 2.3.4 banner regex to the asset inventory ban-list.
- Schedule monthly vulnerability scans (Nessus, OpenVAS, or equivalent) against the internal segment to catch any reintroduction.
- Deploy the Suricata signature R2 (see Detection Engineering section) as a defence-in-depth layer to alert on banner exposure if the service is reintroduced inadvertently.
- Audit the host configuration management (Ansible, Puppet, manual builds) to determine how a 2011-vintage package reached production.

References and articles:

<https://nvd.nist.gov/vuln/detail/CVE-2011-2523>

<https://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html>

<https://docs.rapid7.com/metasploit/metasploitable-2/>

12. Extended low-and-slow reconnaissance phase preceding the exploit

Severity:

MEDIUM

Finding type:

Threat actor behaviour (TTPs)

CVSS v3.1 base score:

5.3 (Medium) - AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CWE:

N/A (TTP characterisation, not a vulnerability)

MITRE ATT&CK:

T1595.002 (Active Scanning: Vulnerability Scanning), T1078.003 (Valid Accounts: Local Accounts), T1589 (Gather Victim Identity Information)

Affected scope:

- Source IP: 172.16.50.10 (attacker)

Description:

The attacker 172.16.50.10 conducted reconnaissance against the target over a window of **at least 15 hours** before triggering the exploit. The earliest FTP CONNECT event in the Wazuh event history dates to **May 9 07:48 UTC**, while the exploit occurred at **May 9 22:53 UTC**. The PCAP capture begins at 20:08 UTC and shows the final 2h40 of this phase.

The reconnaissance cadence was deliberately slow (one connection every 20-90 minutes) to evade simple rate-based detection rules. Two distinct patterns are visible:

Pattern A - Anonymous content mapping (7 occurrences): USER anonymous → PASS guest@ → LIST → QUIT. Used to verify continued service availability and enumerate anonymous-readable content.

Pattern B - Username enumeration (5 occurrences): USER <account> → PASS wrongpassword → QUIT attempted against ftpuser, admin, test, backup, webmaster. The literal use of wrongpassword as the password value indicates **the goal was not credential guessing** - the attacker intended to fail authentication while observing whether the server's response timing or message varied between existing and non-existing accounts.

Proof of evidence - extended timeline via Wazuh

The Wazuh rule 11452 fired with the following CONNECT history (excerpt):

```
Sat May 9 07:48:25 2026 [pid 5482] CONNECT: Client "172.16.50.10"
Sat May 9 13:23:15 2026 [pid 6517] CONNECT: Client "172.16.50.10"
Sat May 9 15:51:04 2026 [pid 6973] CONNECT: Client "172.16.50.10"
Sat May 9 17:34:12 2026 [pid 7321] CONNECT: Client "172.16.50.10"
Sat May 9 18:53:24 2026 [pid 7574] CONNECT: Client "172.16.50.10"
Sat May 9 19:05:38 2026 [pid 7618] CONNECT: Client "172.16.50.10"
```

The PCAP-visible segment (20:08 → 22:12 UTC) shows 12 additional connections in the same slow-paced pattern.

How to distinguish from normal traffic

The combination of (a) a single external source IP, (b) attempts spaced every 20-90 minutes, (c) consistent use of the placeholder password wrongpassword, and (d) no actual file transfers despite multiple successful anonymous logins, is not characteristic of legitimate FTP usage. Existing Wazuh rules detect *fast* brute-force (12 connects in 60 seconds for rule 11452, 8 failed PAM auths in 120 seconds for rule 5551), but the steady cadence between PCAP-visible waves stays well below these thresholds.

Recommendation:

- Deploy a network IDS (Suricata) on the segment ingress. Use the Suricata rule R7 delivered with this engagement (slow FTP USER enumeration: 5+ attempts in 30 minutes from a single source).
- Author Wazuh correlation rules that aggregate FTP/SSH/HTTP recon signals from the same source IP across a 6-hour window with a low per-signal threshold (e.g. 3+ signals across protocols = alert).
- Implement source-IP reputation lookups (e.g. AbuseIPDB, Spamhaus DROP) at the firewall layer to flag known-bad IPs preemptively.
- Consider geo-fencing the FTP endpoint if the legitimate user population is limited to known geographies.

References and articles:

<https://attack.mitre.org/techniques/T1595/002/>

NIST SP 800-94 - Guide to Intrusion Detection and Prevention Systems

13. CVE-2011-2523 exploitation via USER smiley backdoor trigger

Severity:

HIGH

Finding type:

Successful exploitation event

CVSS v3.1 base score:

9.8 (Critical base, rated High at finding level) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CWE:

CWE-78 (Improper Neutralization of Special Elements used in an OS Command)

MITRE ATT&CK:

T1190 (Exploit Public-Facing Application), T1133 (External Remote Services)

Affected scope:

- Event timestamp: May 9 22:53:31 UTC

Description:

At 22:53:31 UTC on May 9, the attacker 172.16.50.10 sent a single FTP USER command whose argument terminates with the smiley sequence :). This triggers the vsftpd 2.3.4 backdoor described in finding I1, causing the server to fork a child process that opens a listener on TCP port 6200 (see finding I4 for the post-exploit shell session).

Crucially, **this is the only FTP attempt in the entire 5h30 capture that does not end with a QUIT command**. All twelve preceding reconnaissance attempts terminate normally with QUIT. The abrupt termination at this attempt is the signature of successful backdoor activation - the attacker has no further use for the FTP control channel because the backdoor has now exposed a separate root shell on port 6200.

An important defender note: **searching for the username baduser in the Wazuh logs returns zero results**. vsftpd 2.3.4 does not log its own exploitation; the backdoor forks the shell before any session log entry is written. This means a properly-configured SIEM with vsftpd log ingestion cannot detect this specific exploit via log review alone. Detection must occur at the **network layer** (Suricata or equivalent NIDS observing the FTP USER command in transit) or via host-level process-execution monitoring (auditd execve).

Proof of evidence - exploit packet

```
$ tshark -r attack.pcap -Y 'ftp.request.command == "USER" && ip.src == 172.16.50.10' \
-T fields -e frame.time -e ftp.request.arg | grep baduser
May 9, 2026 22:53:31 UTC    baduser:)
```

The follow-up PASS command and the flow termination:

```
$ tshark -r attack.pcap -Y "tcp.stream eq 68 && ftp" -T fields \
  -e frame.time -e ftp.request.command -e ftp.request.arg
May  9, 2026 22:53:31.812896    USER    baduser:)
May  9, 2026 22:53:32.813763    PASS     anything
[flow terminates - no QUIT, no further FTP commands in this stream]
```

Detection

The Suricata rule R1 (delivered in Phase 2) detects this exploit attempt with the following content match: USER command on TCP/21 whose argument matches the pcre `/^USER\s+\S*:\)\r?\n/i`. Validation by PCAP replay confirms the rule fires exactly once for this incident, with no false positives across the entire 5,194-packet capture.

Recommendation:

- The primary remediation is **I1 itself**: remove the vulnerable service. Once vsftpd 2.3.4 is decommissioned, this exploit becomes structurally impossible.
- As a defence-in-depth layer, deploy Suricata rule R1 on the segment ingress. The rule has near-zero false-positive risk because no legitimate FTP client uses a smiley in a username.
- Configure the SIEM to escalate any Suricata alert with classtype attempted-admin on the FTP service to immediate notification.

References and articles:

<https://nvd.nist.gov/vuln/detail/CVE-2011-2523>

Metasploit module: `exploit/unix/ftp/vsftpd_234_backdoor`

14. Unauthenticated root bind shell on TCP/6200, 8 enumeration commands executed

Severity:

CRITICAL

Finding type:

Active root-level compromise

CVSS v3.1 base score:

10.0 (Critical) - AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

CWE:

CWE-78 chained with CWE-269 (Improper Privilege Management)

MITRE ATT&CK:

T1059.004 (Unix Shell), T1033, T1082, T1087.001, T1083, T1016, T1049

Affected scope:

- Session: May 9 22:53:35 → 22:53:55 UTC (~20 seconds)

Description:

Approximately 4 seconds after the exploit trigger documented in I3, the attacker established a TCP connection from 172.16.50.10:41174 to the backdoor listener at 192.168.10.10:6200 and obtained an interactive root shell. The shell session lasted approximately 20 seconds and contained 8 commands. All shell content was transmitted in cleartext (the backdoor uses no encryption), allowing complete reconstruction from the PCAP.

#	Command	Response (excerpt)	MITRE
1	id	uid=0(root) gid=0(root) groups=0(root)	T1033
2	whoami	root	T1033
3	uname -a	Linux metasploitable 2.6.24-16-server #1 SMP i686	T1082
4	hostname	metasploitable	T1082
5	cat /etc/passwd head -10	10 system accounts dumped	T1087.001
6	ls /home	ftp / msfadmin / service / user	T1083
7	ifconfig	eth0: 192.168.10.10/24, MAC bc:24:11:98:04:3f	T1016
8	netstat -an grep LISTEN	22 listening services enumerated	T1049

Operational observations

The shell session contains **only reconnaissance commands**. There are no destructive actions, no file modifications, no downloads, no command-and-control beacon installations, and no persistence mechanisms visible in this stream. The 22 additional listening services enumerated by netstat (including OpenSSH 4.7, MySQL 3306 exposed externally, Tomcat 8180 with default credentials, ingreslock backdoor on port 1524) constitute high-value information for follow-up attacks.

The kernel version (2.6.24-16-server, April 2008) and the hostname (metasploitable) identify the operating system as **Metasploitable 2**, a Linux distribution by Rapid7 deliberately built with vulnerable

services for security training. Its presence on a NexaCorp internal server is itself a finding of significant concern.

Proof of evidence - TCP stream reconstruction

```
$ tshark -r attack.pcap -q -z follow,tcp,ascii,70 | head -50
=====
Follow: tcp,ascii
Filter: tcp.stream eq 70
Node 0: 172.16.50.10:41174
Node 1: 192.168.10.10:6200
=====
      id
      uid=0(root) gid=0(root) groups=0(root)
      whoami
      root
      uname -a
      Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 i686
      [...]
```

Recommendation:

- **P0 - Take the host offline immediately** and conduct full forensic acquisition (disk image + memory dump) before any cleanup. Even though this specific shell session contained no persistence, the host may have been compromised again post-PCAP via other means.
- Deploy Suricata rule R3 (inbound TCP/6200 detection) on the segment ingress.
- Add TCP port 6200 to the firewall deny-list for inbound traffic, then audit for any legitimate use of that port (none expected).
- Configure auditd execve monitoring on critical hosts to catch shell-spawned-by-non-shell-parent events (a backdoor shell forked by vsftpd is exactly that pattern).

References and articles:

SANS PICERL - Incident Response Process (Containment phase guidance)

NIST SP 800-86 - Guide to Integrating Forensic Techniques into Incident Response

15. Pre-existing MITRE Caldera Sandcat C2 implant (independent of the FTP attack)

Severity:

CRITICAL

Finding type:

Pre-existing compromise (active C2 channel)

CVSS v3.1 base score:

9.6 (Critical) - AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:L

CWE:

CWE-506 (Embedded Malicious Code)

MITRE ATT&CK:

T1071.001 (Web Protocols), T1029 (Scheduled Transfer), T1102 (Web Service)

Affected scope:

- C2 endpoint: 10.40.0.200:8888 (external, non-NexaCorp)

Description:

This finding directly corresponds to the 'unusual outbound connection' originally flagged by the NexaCorp IT team. The compromised host 192.168.10.10 is running an instance of **MITRE Caldera's 'Sandcat' agent** - a publicly available open-source post-exploitation framework used in red-team exercises and occasionally repurposed by sophisticated threat actors. The agent is installed at /opt/caldera/sandcat and runs as **root** (PID 4749, parent PID 1, i.e. daemonised under init/systemd).

The agent is **already active at the first packet of the PCAP** (May 9 20:08:30 UTC), beaconing to 10.40.0.200:8888 via HTTP POST requests every 37-53 seconds. Throughout the captured 5h30 window, the C2 conversation comprises 2,218 packets and transfers 572 KB. The C2 channel **predates the FTP exploit documented in I3** and is most likely the result of a separate, earlier compromise whose initial-access vector is not represented in the evidence package.

Proof of evidence - decoded beacon payload

The beacon body is Base64-encoded JSON. Decoded:

```
{
  "exe_name":      "sandcat",
  "location":      "/opt/caldera/sandcat",
  "paw":           "mesdec",
  "pid":           4749,
  "ppid":          1,
  "host":          "metasploitable",
  "username":      "root",
  "privilege":      "Elevated",
  "platform":      "linux",
  "architecture":  "386",
  "server":        "http://10.40.0.200:8888",
  "group":         "lab-unknown",
  "executors":     ["proc", "sh"]
}
```

The C2 server response (Caldera operator side, decoded from Base64):

```
{"paw": "mesdec", "sleep": 37, "watchdog": 0, "instructions": "[]"}

```

Throughout the captured window, the C2 operator sends no instructions (the instructions field is consistently empty). The implant is in standby, waiting for tasks. This is consistent with two operational hypotheses: either the operator is observing without actively tasking, or this is a long-dwell access channel reserved for future use.

Network correlation - separate from FTP attack

The attacker IP for the FTP exploit (I3) is 172.16.50.10. The C2 server IP is 10.40.0.200. These are in different subnets, the protocols are different (FTP vs. HTTP), and the operational tempo is different (one-shot exploit vs. sustained beaconing). The two compromises are very likely the work of **two distinct threat actors**.

Recommendation:

- **P0 - IMMEDIATE.** Quarantine the host from the network. Acquire memory and disk images before any cleanup operation.
- Conduct full forensic analysis of `/opt/caldera/sandcat` and its parent directory. Enumerate persistence mechanisms (systemd units, cron jobs, init.d scripts, rc.local entries, kernel modules).
- Investigate the process tree for PID 4749. The parent PID 1 indicates the daemon was either started directly by init/systemd or re-parented after the original launcher exited.
- Implement an **egress allowlist** for internal servers. This would have prevented the Caldera beacon entirely.
- Deploy Suricata rules R4 (Caldera beacon detection) and R5 (Caldera C2 server response detection) on the segment egress.
- Audit other NexaCorp internal hosts for the presence of `/opt/caldera/sandcat`, the `Go-http-client/1.1` user-agent in egress proxy logs, or HTTP POST requests to `/beacon`.

References and articles:

<https://caldera.mitre.org/>

<https://github.com/mitre/sandcat>

<https://attack.mitre.org/techniques/T1071/001/>

I6. Multi-protocol service enumeration

Severity:

LOW

Finding type:

Reconnaissance activity

CVSS v3.1 base score:

3.7 (Low) - AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

CWE:

CWE-200 (Information Exposure)

MITRE ATT&CK:

T1046 (Network Service Discovery), T1592.002 (Gather Victim Host Information: Software)

Affected scope:

- Source IP: 172.16.50.10 (attacker)
-

Description:

Beyond the FTP-focused reconnaissance documented in I2, the attacker 172.16.50.10 performed banner-grabbing reconnaissance against five additional services exposed on the target host. The HTTP enumeration was conducted from curl/7.81.0 and wget/1.21.2 user-agents - the signature of automated tooling, not a human browser. The HTTP path enumeration sequence (/admin, /login, /phpmyadmin) matches common content-discovery wordlists (ffuf, dirb, gobuster default lists).

Protocol	Port	Activity	Detail
HTTP	80	26+ GET requests	Paths: /, /robots.txt, /index.php, /admin, /login, /phpmyadmin (CLI user-agents)
SSH	22	2 banner grabs	SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1 (2007 vintage)
SMTP	25	3 banner grabs	Postfix Ubuntu banner
Telnet	23	2 connections	Banner only, no credentials submitted
MySQL	3306	1 frame	Server greeting captured

Recommendation:

- Disable unused services on internal hosts: Telnet/23 (deprecated, no business use case), externally-exposed MySQL/3306 (should be internal-only), phpMyAdmin if not actively used.
- Implement service-banner suppression at the application layer where supported (e.g. `VersionAddendum none + DebianBanner no` for OpenSSH, `smtpd_banner` in Postfix).
- Deploy Suricata rule R6 (HTTP admin-path enumeration from CLI user-agents) to catch this recon pattern in real time.

References and articles:

<https://attack.mitre.org/techniques/T1046/>

NIST SP 800-94 - Guide to Intrusion Detection and Prevention Systems

17. SSH brute-force attempts visible in Wazuh, outside PCAP capture window

Severity:

MEDIUM

Finding type:

Authentication brute-force activity

CVSS v3.1 base score:

5.3 (Medium) - AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CWE:

CWE-307 (Improper Restriction of Excessive Authentication Attempts)

MITRE ATT&CK:

T1110 (Brute Force), T1110.001 (Password Guessing)

Affected scope:

- Source IP: 172.16.50.10 - Target SSH service on 192.168.10.10:22

Description:

The Wazuh CSV export reveals SSH and PAM authentication activity from 172.16.50.10 that is not visible in the PCAP (which only captured 2 SSH banner-grab frames as part of I6). The activity occurred partially outside the 5h30 PCAP window and indicates the attacker also attempted SSH credential brute-force against the target.

Wazuh rule.id	Description	Level	Count
5503	PAM: User login failed	5	16
5706	sshd: insecure connection attempt (scan)	6	12
5551	PAM: Multiple failed logins in a small period of time	10	2
5715	sshd: authentication success	3	12

Analysis

The 16 failed PAM authentications crossed Wazuh rule 5551's threshold (8 fails in 120 seconds) twice, generating two level-10 alerts. These are **among the only four high-severity alerts** raised for the entire incident (see I9 for the complete SIEM coverage analysis).

The 12 SSH authentication successes (rule 5715) require closer inspection. They may include both legitimate administrative sessions (the msfadmin account from 192.168.10.1 visible in auth.log the morning after the incident) and potentially attacker-controlled sessions if any credentials were obtained through this brute-force activity. The full_log field for each of these 12 events was not exported in the CSV provided to the investigator, and pulling them is part of the recommended follow-up.

Recommendation:

- Pull the `full_log` field for all 12 rule-5715 events and identify the authenticating username + source IP for each. Cross-reference against the legitimate administrator accounts list.
- Enforce `PubkeyAuthentication` only (disable password authentication) on any internet-reachable SSH endpoint.
- Configure `fail2ban` or equivalent IP-based lockout with a 30-minute ban after 5 failed attempts.
- Confirm Wazuh rule 5551 (level 10) is escalated to immediate notification via Slack, email, or PagerDuty.

References and articles:

<https://attack.mitre.org/techniques/T1110/001/>
<https://cwe.mitre.org/data/definitions/307.html>

18. Anomalous sudo activity including first-time-sudo events

Severity:

HIGH

Finding type:

Post-exploitation indicator (requires further investigation)

CVSS v3.1 base score:

7.2 (High) - AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

CWE:

CWE-269 (Improper Privilege Management)

MITRE ATT&CK:

T1548.003 (Sudo and Sudo Caching) - possible

Affected scope:

- Compromised host: 192.168.10.10 (sudo events from Wazuh SIEM)

Description:

The Wazuh CSV reveals **80 sudo-related events** in the agent's history for the period covered by the SIEM ingestion:

Wazuh rule.id	Description	Level	Count
5402	Successful sudo to ROOT executed	3	61
5407	Successful sudo executed	3	17
5403	First time user executed sudo	4	2

The most concerning indicator is rule 5403, which fired twice. This rule fires the very first time a given user account executes sudo on a host. When a user that has never used sudo on a system suddenly does so, this is a classic post-exploitation signal - either an attacker leveraging compromised credentials, or a legitimate user with newly-assigned privileges. In this specific incident, the timing relative to the FTP exploitation event needs to be confirmed by pulling the `full_log` field from Wazuh.

Limitation of this finding

This finding has not been fully resolved during the engagement because the `full_log` field for the 80 sudo events was not exported in the CSV provided to the investigator. To complete this finding, the recommended action below must be executed.

Recommendation:

- **P1 - Pull full_log from Wazuh** for all 80 sudo events (rule.id 5402 + 5407 + 5403). Identify: which user accounts triggered each event, at what timestamps relative to the FTP exploit (May 9 22:53 UTC), and which commands were executed under sudo.
- Particular attention to rule 5403 (first-time-sudo): the two affected accounts must be identified and their recent activity audited.
- Configure auditd with execve monitoring on critical hosts; this provides far richer detail than Wazuh's sudo events alone.
- Implement a Wazuh correlation rule: *'first-time-sudo within 24 hours of a brute-force level-10 alert on the same host = critical alert'*. This would have surfaced the pattern observed here automatically.

References and articles:

<https://attack.mitre.org/techniques/T1548/003/>
<https://cwe.mitre.org/data/definitions/269.html>

19. Insufficient Wazuh SIEM detection coverage

Severity:

HIGH

Finding type:

Defensive control deficiency

CVSS v3.1 base score:

N/A (defensive deficiency, not a vulnerability per se)

CWE:

CWE-778 (Insufficient Logging) - extended to insufficient correlation

MITRE ATT&CK:

N/A (this finding describes a gap in detection, not an attack technique)

Affected scope:

- NexaCorp Wazuh 4.x SIEM, agent 020 (blue11, 192.168.100.60)

Description:

Analysis of the Wazuh SIEM coverage for this incident demonstrates a significant detection gap. Using the filter `location: *nexacorp* AND agent.id: 020`, the investigator retrieved 397 events ingested for the affected host during the incident period. The severity distribution is dominated by low-severity informational events:

Rule level	Count	%	Severity classification
3	351	88.4%	Low (informational)
4	2	0.5%	Low
5	28	7.1%	Low-Medium
6	12	3.0%	Medium
10	4	1.0%	High
≥12	0	0%	(none reached critical)

Root causes of the detection gap

- **No application-level exploit detection.** Wazuh rules for vsftpd only parse syslog-style events (CONNECT, LOGIN OK/FAIL). They do not parse the USER argument or look for exploit patterns. A search for the literal string baduser in all 397 events returns zero results.
- **No network IDS integration.** The Caldera beacon and bind shell traffic are structurally invisible to a host-based SIEM agent. The Wazuh agent receives logs from the host's local services but has no visibility into the network layer.
- **No process / file integrity monitoring for /opt/caldera/sandcat.** The implant binary's installation was not detected because Wazuh FIM was not configured on that path.

- **Brute-force rules detect collateral signals only.** The four level-10 alerts correctly identify 'abnormal connection volume' but do not surface the actual intrusion path.
- **Signal-to-noise ratio.** 88.4% of events are level 3 (informational). Four high-severity alerts out of 397 = 1.0% - easily dismissed as routine brute-force activity in a real SOC.

Recommendation:

- Deploy the seven Suricata detection rules delivered in Phase 2 of this engagement (see Detection Engineering section).
- Author Wazuh correlation rules combining existing brute-force signals (rules 11452, 5551, 5503) with first-time-sudo events (rule 5403) within a short time window to elevate severity automatically.
- Configure Wazuh FIM (File Integrity Monitoring) on /opt/, /usr/local/bin/, /etc/init.d/, /etc/systemd/system/, and other persistence-typical paths.
- Integrate the Suricata eve.json output with Wazuh as a log source. This brings network-layer detection into the unified alert queue.
- Configure escalation policies: level-10 PAM brute-force from external IP must be paged within 5 minutes; level-10 FTP brute-force from external IP must be paged within 15 minutes.

References and articles:

<https://cwe.mitre.org/data/definitions/778.html>

NIST SP 800-61r2 - Computer Security Incident Handling Guide

I10. Host audit logs do not cover the incident window

Severity:

LOW

Finding type:

Forensic readiness deficiency

CVSS v3.1 base score:

N/A (forensic readiness gap)

CWE:

CWE-778 (Insufficient Logging)

MITRE ATT&CK:

N/A (this finding describes a logging gap)

Affected scope:

- Compromised host: 192.168.10.10 - host audit logs (/var/log/auth.log, /var/log/syslog)
-

Description:

The host audit logs provided in the evidence package (auth.log 3.3 KB, syslog 22 KB) **do not overlap with the incident window**. The first entry in syslog is timestamped May 10 06:37:10 UTC and reads syslogd restart - indicating that the system was rebooted approximately 5 hours after the PCAP capture ended. The first entry in auth.log is May 10 06:47 UTC. Both files therefore begin **after** the attack and contain only post-incident administrative activity (notably msfadmin sessions from 192.168.10.1, presumably the investigation team).

The absence of host-level logs for the 22:53 UTC time frame eliminates a critical corroborating source. Combined with the fact that vsftpd does not log its own exploitation (see I3), and that the Wazuh agent was experiencing ingestion pipeline issues during the actual incident, the multi-source corroboration of the FTP exploit relies solely on the PCAP.

Recommendation:

- Enable extended log retention (90 days minimum, ideally 180 days) on all NexaCorp internal hosts.
- Ship logs off-host in near-real-time to the central SIEM (Wazuh agent already provides this; just verify the ingestion pipeline reliability).
- Configure log rotation with rsyslog compression and remote forwarding to ensure logs survive host reboots.
- Enable auditd on critical hosts with rules covering execve, file integrity on /etc/passwd + /etc/shadow, and authentication events.
- Verify log forwarding via periodic SIEM-side ingestion checks (Wazuh agent heartbeat alerts).

References and articles:

<https://cwe.mitre.org/data/definitions/778.html>

NIST SP 800-92 - Guide to Computer Security Log Management

Detection Engineering (Phase 2)

A. Methodology

Phase 2 of this engagement delivers a set of seven Suricata 6.0.4 detection rules implementing the detections recommended throughout the Investigation Technical Summary. Each rule is mapped to one or more findings (I1-I10) and addresses a specific gap identified in the existing detection coverage.

The rules were authored against the captured PCAP attack.pcap to ensure each detection covers a specific incident artifact. Validation was performed via offline replay: the PCAP was injected into a monitored interface (ens19) using tcpreplay, and Suricata's alerts (written to fast.log and eve.json) were inspected to confirm each rule fired correctly.

Deployment environment:

Component	Value
Suricata version	6.0.4 RELEASE
Engine mode	AFPacket, single-thread (no Hyperscan; SSSE3 not on host)
Rules path	/etc/suricata/rules/learner/lab.rules
SID range	9000001-9000099 (analyst-local, no conflict with vendor rule sets)
Test PCAP	5,194 packets, MTU-trimmed to 1400 for the lab interface
Replay command	tcpreplay --intf1=ens19 --topspeed /tmp/attack_mtu.pcap

B. Rule catalog (R1 - R7)

SID	Name	Detection logic	Layer	MITRE	Covers
9000001 (R1)	vsftpd 2.3.4 USER smiley exploit	FTP USER command on TCP/21 whose argument matches pcre /^USER[is+S*:]\\r?\\n/i	TCP/21 payload	T1190	I3
9000002 (R2)	vsftpd 2.3.4 banner	FTP server greeting on TCP/21 containing literal '220 (vsFTPd 2.3.4)' in first 30 bytes	TCP/21 payload	T1190	I1
9000003 (R3)	Inbound TCP/6200 backdoor connection	SYN-only packet to destination port 6200, throttled to 1 alert per source IP per minute	TCP/6200 SYN	T1059.004	I4
9000004 (R4)	Caldera Sandcat beacon	TCP payload containing 'POST /beacon' followed by 'Go-http-client/1.1' (port-agnostic)	TCP content	T1071.001, T1102	I5
9000005 (R5)	Caldera C2 server response	TCP payload containing 'Server: Python/3.10 aiohttp', throttled to 1 per source per 300s	TCP content	T1071.001	I5
9000006 (R6)	HTTP admin path enumeration	HTTP GET to admin-like paths (/admin, /login, /phpmyadmin) from curl or Wget user-agent, with 3-per-300s threshold	TCP/80 payload	T1595.002, T1592.002	I6
9000007 (R7)	Slow FTP USER enumeration	5+ FTP USER commands from same source IP within 30 minutes (catches low-and-slow recon below Wazuh thresholds)	TCP/21 payload + threshold	T1589, T1078.003	I2

Full rule text and reasoning:***R1 - vsftpd 2.3.4 USER smiley exploit (SID 9000001)***

```

alert tcp any any -> any 21 ( \
  msg:"INC-2026-001 - vsftpd 2.3.4 backdoor trigger (CVE-2011-2523) - USER ending with
  smiley"; \
  flow:to_server,established; \
  content:"USER "; depth:5; \
  pcre:"/^USER\s+\S*:\)\r?\n/i"; \
  reference:cve,2011-2523; \
  reference:url,scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.htm
l; \
  classtype:attempted-admin; \
  metadata:author Johan-Emmanuel Hatchi, mitre_attack T1190; \
  sid:9000001; rev:1;)

```

Reasoning per keyword:

- `alert tcp any any -> any 21`: port-21-bound match. In the lab both attacker and target are in RFC1918 space, so we use any on both sides; in production this must be scoped to the FTP server's IP.
- `flow:to_server,established`: only client-to-server packets in an established TCP session (eliminates handshake packets from inspection).
- `content:"USER "; depth:5`: match the literal FTP USER command at offset 0 in payload. `depth:5` restricts the search window to the first 5 bytes for efficiency.
- `pcre:"/^USER\s+\S*:\)\r?\n/i"`: strict regex matching USER followed by any non-whitespace ending with :). The `\r?\n` captures the line terminator. Case-insensitive.

R2 - vsftpd 2.3.4 vulnerable banner (SID 9000002)

```

alert tcp any 21 -> any any ( \
  msg:"INC-2026-001 - vsftpd 2.3.4 vulnerable banner advertised (CVE-2011-2523)"; \
  flow:from_server,established; \
  content:"220 (vsFTPd 2.3.4)"; depth:30; \
  reference:cve,2011-2523; \
  classtype:misc-attack; \
  metadata:author Johan-Emmanuel Hatchi, mitre_attack T1190; \
  sid:9000002; rev:1;)

```

Reasoning per keyword:

- `alert tcp any 21 -> any any`: server-to-client traffic from any FTP server on port 21.
- `flow:from_server,established`: only server replies in established sessions (eliminates SYN-ACK and unrelated traffic).
- `content:"220 (vsFTPd 2.3.4)"; depth:30`: match the banner string within the first 30 bytes of payload. FTP banners always begin with code 220 followed by the parenthesised server name.

R3 - Inbound TCP/6200 backdoor connection (SID 9000003)

```
alert tcp any any -> any 6200 ( \
  msg:"INC-2026-001 - Inbound connection to suspicious port 6200 (vsftpd 2.3.4 backdoor bind
  shell)"; \
  flags:S,12; \
  flow:to_server,not_established; \
  threshold:type limit, track by_src, count 1, seconds 60; \
  reference:cve,2011-2523; \
  classtype:trojan-activity; \
  metadata:author Johan-Emmanuel Hatchi, mitre_attack T1059.004; \
  sid:9000003; rev:1;)
```

Reasoning per keyword:

- `alert tcp any any -> any 6200`: target on port 6200 (the hardcoded port of the vsftpd 2.3.4 backdoor shell).
- `flags:S,12`: SYN flag set, no ACK (connection initiation attempt). Mask 12 includes CWR/ECE bits for ECN; ignores PSH/URG/FIN/RST.
- `flow:to_server,not_established`: direction explicit for SYN-only packets. Without this, Suricata raises `SC_WARN_POOR_RULE`.
- `threshold:type limit, track by_src, count 1, seconds 60`: throttle to 1 alert per source IP per minute. Prevents log flood if the attacker port-scans 6200 repeatedly.

R4 - Caldera Sandcat beacon (SID 9000004)

```

alert tcp any any -> any any ( \
  msg:"INC-2026-001 - MITRE Caldera Sandcat agent beacon detected (POST /beacon +
Go-http-client UA)"; \
  content:"POST /beacon"; \
  content:"Go-http-client/1.1"; distance:0; \
  threshold:type limit, track by_src, count 1, seconds 60; \
  reference:url,caldera.mitre.org; \
  classtype:trojan-activity; \
  metadata:author Johan-Emmanuel Hatchi, mitre_attack T1071.001, mitre_attack T1102; \
  sid:9000004; rev:3;)

```

Reasoning per keyword:

- `alert tcp any any -> any any`: port-agnostic. Originally written with `alert http`, but the HTTP parser only inspects port 80 by default and Caldera C2 runs on 8888 (see Section D below).
- `content:"POST /beacon"`: exact byte match for the request line.
- `content:"Go-http-client/1.1"; distance:0`: match the User-Agent header. `distance:0` ensures it appears after the POST line in the same payload.
- `threshold:... seconds 60`: Caldera beacons every 37-53 seconds (sleep:37 with observed jitter); throttle to 1 alert per minute to keep fast . log readable.

R5 - Caldera C2 server response (SID 9000005)

```

alert tcp any any -> any any ( \
  msg:"INC-2026-001 - Caldera C2 server response detected (Python aiohttp Server header)"; \
  content:"Server: Python/3.10 aiohttp"; \
  threshold:type limit, track by_src, count 1, seconds 300; \
  reference:url,caldera.mitre.org; \
  classtype:trojan-activity; \
  metadata:author Johan-Emmanuel Hatchi, mitre_attack T1071.001; \
  sid:9000005; rev:3;)

```

Reasoning per keyword:

- `alert tcp any any -> any any`: port-agnostic (same reasoning as R4).
- `content:"Server: Python/3.10 aiohttp"`: distinctive header from the Caldera C2 server's aiohttp framework. The version suffix /3.13.4 is intentionally omitted to remain robust against minor version updates.
- `threshold:... seconds 300`: 5-minute throttle. Caldera sessions are long-lived (5h30 in this incident); 1 alert per source per 5 min provides sufficient visibility without flooding.

R6 - HTTP admin path enumeration (SID 9000006)

```

alert tcp any any -> any 80 ( \
  msg:"INC-2026-001 - HTTP admin path enumeration (admin/login/phpmyadmin) from automated
  tool"; \
  content:"GET /"; depth:5; \
  pcre:"/GET \/(admin|login|phpmyadmin)/i"; \
  pcre:"/User-Agent:\s+(curl|wget)/i"; \
  threshold:type limit, track by_src, count 3, seconds 300; \
  classtype:web-application-attack; \
  metadata:author Johan-Emmanuel Hatchi, mitre_attack T1595.002, mitre_attack T1592.002; \
  sid:9000006; rev:2;)

```

Reasoning per keyword:

- `alert tcp any any -> any 80`: match on HTTP traffic on port 80. This rule is intentionally port-bound (HTTP traffic is overwhelmingly on 80); a port-agnostic variant would need to detect HTTP wire format on non-standard ports and increase FP risk. HTTPS evasion is possible (see Section F).
- `content:"GET /"; depth:5`: match HTTP GET method at start of payload (more efficient than a full pcre on every packet).
- `pcre:"/GET \/(admin|login|phpmyadmin)/i"`: match any of the three admin-like paths probed during reconnaissance (case-insensitive). This is broader than the v1 rule which only matched phpmyadmin and would have missed the /admin and /login probes observed in finding I6.
- `pcre:"/User-Agent:\s+(curl|wget)/i"`: match curl or wget user-agents. These are CLI tools commonly used by automated reconnaissance, not by legitimate human users browsing admin panels through a web browser.
- `threshold:... count 3, seconds 300`: 3 alerts per source per 5 min window. Tuned to avoid alerting on a single curl request (which might be a legitimate admin script) while catching enumeration sweeps.

R7 - Slow FTP USER enumeration (SID 9000007)

```
alert tcp any any -> any 21 ( \
  msg:"INC-2026-001 - Possible FTP username enumeration (5+ USER commands in 30min from
  single src)"; \
  flow:to_server,established; \
  content:"USER "; depth:5; \
  threshold:type threshold, track by_src, count 5, seconds 1800; \
  classtype:attempted-recon; \
  metadata:author Johan-Emmanuel Hatchi, mitre_attack T1589, mitre_attack T1078.003; \
  sid:9000007; rev:1;)
```

Reasoning per keyword:

- `alert tcp any any -> any 21`: FTP traffic.
- `flow:to_server,established`: client-side commands in established session.
- `content:"USER "; depth:5`: match the literal `USER` command at start of payload.
- `threshold:type threshold, track by_src, count 5, seconds 1800`: fire alert when same source IP sends 5+ `USER` commands within 30 minutes. Compatible with low-and-slow attacker cadence; Wazuh rule 11452 only catches 12 connects in 60s, far too tight for the actual attacker behaviour observed in finding I2.

C. Validation results

The PCAP was replayed against the live Suricata instance with the final rule set. All 5,194 packets were injected successfully (0 drops, 0 retries). After deduplication via rule throttles, `fast.log` contains the following alert distribution:

<i>SID</i>	<i>Rule</i>	<i>Alerts</i>	<i>Expected</i>	<i>Status</i>
9000001	vsftpd USER smiley exploit	1	1 (single exploit attempt)	[OK]
9000002	vsftpd 2.3.4 banner	30	14+ (banner per FTP session, with retransmits)	[OK]
9000003	Backdoor TCP/6200 inbound	1	1 (single bind shell connection)	[OK]
9000004	Caldera Sandcat beacon	1	1 (throttled to 1 per 60s)	[OK]
9000005	Caldera C2 server response	1	1 (throttled to 1 per 300s)	[OK]
9000006	HTTP admin path enumeration	3	3+ (admin paths probed)	[OK]
9000007	FTP USER enumeration	3	3+ (threshold met)	[OK]
Total	7 rules	40 alerts	All rules fired correctly	[OK]

The underlying `eve.json` enriched-event log contains 314 alert records for the same replay, because `eve.json` logs every match while `fast.log` reflects the throttling applied to rules R3, R4, R5, and R6. The 40-alert `fast.log` represents the deduplicated operational view that a SOC analyst would see.

Representative alert (the exploit detection):

```
05/11/2026-12:50:38.424606  [**] [1:9000001:1]
INC-2026-001 - vsftpd 2.3.4 backdoor trigger (CVE-2011-2523) - USER ending with smiley
[**] [Classification: Attempted Administrator Privilege Gain] [Priority: 1]
{TCP} 172.16.50.10:59138 -> 192.168.10.10:21
```

Representative Caldera detection:

```
05/11/2026-12:50:38.393890  [**] [1:9000004:3]
INC-2026-001 - MITRE Caldera Sandcat agent beacon detected (POST /beacon + Go-http-client UA)
[**] [Classification: A Network Trojan was detected] [Priority: 1]
{TCP} 192.168.10.10:53872 -> 10.40.0.200:8888
```

This second alert is particularly significant: it identifies the Caldera C2 channel - the original 'unusual outbound connection' that NexaCorp's firewall flagged but did not alert on - in real time, with full classification metadata.

D. Tuning notes & lessons learned

Four iterative fixes were required during deployment. Each fix is documented because it represents a real-world detection-engineering pitfall that operations teams will encounter when porting these rules to production.

1. SYN-only direction warning

Rule R3 initially raised SC_WARN_POOR_RULE: SYN-only to port(s) 6200:6200 w/o direction specified. Fixed by adding `flow:to_server,not_established`, making the direction explicit for the SYN-flagged packet.

2. HOME_NET / EXTERNAL_NET ambiguity

The default Suricata configuration sets `HOME_NET = [192.168.0.0/16, 10.0.0.0/8, 172.16.0.0/12]` and `EXTERNAL_NET = !$HOME_NET`. In a lab environment where attacker, target, and C2 all live in RFC1918 space, `EXTERNAL_NET` becomes empty and rules of the form `$EXTERNAL_NET any -> $HOME_NET 21` never match. The lab fix is to replace these variables with any. For production deployment at NexaCorp, `HOME_NET` must be narrowed.

3. HTTP parser is port-bound

Rules R4 and R5 were originally written with the alert `http` keyword. These depend on Suricata's HTTP parser, which by default only inspects port 80. Caldera C2 runs on port 8888, so the HTTP parser was not engaged on this traffic and the rules never fired. The fix is to rewrite both rules in TCP+content mode (`alert tcp ... content:'POST /beacon'; content:'Go-http-client/1.1'`), which matches the raw HTTP wire bytes regardless of port.

4. flow:established does not settle reliably during PCAP replay

A first attempt at the TCP+content version of the Caldera rules still required `flow:established,to_server`. During offline PCAP replay, Suricata's flow state machine sometimes does not register the TCP handshake of the captured session. Removing `flow:established` from the Caldera rules makes them match correctly in both live and replay modes.

E. False-positive analysis

Rule	FP likelihood	Mitigation
R1 - USER smiley	Negligible	No legitimate FTP client uses :) in a username
R2 - vsftpd banner	None for the version match	Banner is a known-vulnerable fingerprint
R3 - TCP/6200	Low (if 6200 unused)	Confirm 6200 has no legitimate use before deployment
R4 - Caldera beacon	Low	Go-http-client/1.1 is also used by some legitimate Go-based tools (Kubernetes, Docker). Throttle + combine with destination reputation
R5 - Caldera C2 response	Low-Medium	Python/3.10 aiohttp is used by many legitimate Python services. Tune by restricting destinations
R6 - HTTP admin enum	Medium	Legitimate use of curl/Wget against /phpmyadmin is rare but possible. Tune to exclude known admin source IPs
R7 - FTP USER enum	Low	5-attempts-in-30min threshold unlikely to trigger on legitimate use

F. Evasion considerations

The rules detect the **specific signatures** of the captured incident. A sophisticated attacker could evade them in three ways:

- **Modify the exploit smiley payload** - for example, send USER :) as USER :) \x00 with a trailing null byte. Robust detection would require matching the FTP control channel state machine rather than literal byte patterns.
- **Custom Caldera build** - recompile Sandcat with a different User-Agent string or a non-default beacon path. Defence in depth: add behavioural rules looking for periodic small HTTP POST requests to non-whitelisted destinations regardless of UA.
- **Encrypted C2** - switch Caldera to HTTPS. Then payload inspection is impossible. The fallback is TLS metadata analysis (JA3/JA4 fingerprints), destination reputation, and traffic-pattern analysis (constant beacon cadence).

These limitations should be considered in NexaCorp's longer-term detection strategy. The rules delivered here are appropriate for the current threat scenario but should be supplemented with behavioural and metadata-based detections as the threat landscape evolves.

G. Beyond-detection recommendations

Detection alone is insufficient. The seven Suricata rules delivered here would have alerted NexaCorp's SOC about this attack in real time, but **alerting is reactive**. The following recommendations aim to **prevent** this class of attack from succeeding in the first place, or to reduce the impact when it does. They are prioritised P0 (immediate, within 24-48h) through P3 (ongoing maturity).

P0 - Immediate (within 24-48 hours)

#	Recommendation	Rationale
P0-1	Quarantine the affected host (192.168.10.10). Acquire memory and disk images via standard forensic tooling (LiME, dd) before any cleanup.	Finding I5: pre-existing Caldera C2 implant of unknown origin. Forensic preservation is irreplaceable once the host is wiped.
P0-2	Decommission or upgrade vsftpd 2.3.4 . Migrate to OpenSSH/SFTP if FTP is not strictly required, otherwise upgrade to ≥ 3.0.x.	Finding I1: vulnerable since July 2011. No detection rule can match an exploit that no longer reaches a vulnerable service.
P0-3	Reconfigure the firewall to ALERT on outbound connections to non-whitelisted destinations, not merely log them.	The Caldera beacon was logged but never alerted. Conversion to alert mode is a configuration change, not a deployment.

P1 - Short term (within 1-2 weeks)

#	Recommendation	Rationale
P1-1	Deploy a network IDS (Suricata) on the segment ingress with the 7 rules delivered in this engagement.	Wazuh has no network telemetry; the Caldera C2 and bind shell were structurally invisible to it.
P1-2	Implement Wazuh correlation rules combining brute-force signals (rules 11452, 5551, 5503) with first-time-sudo events (rule 5403) within a short time window.	Finding I9: Wazuh has the raw signals but no correlation between them. The data is there; it just needs to be elevated.
P1-3	Inventory all NexaCorp internal servers and remove any Metasploitable 2 instances.	Metasploitable is a training image, not a production OS. Its presence indicates serious asset management gaps.
P1-4	Investigate the 80 sudo events and 12 SSH authentication successes identified in findings I7 and I8. Pull full_log for each event.	These may reveal additional compromised accounts not yet identified.
P1-5	Upgrade OpenSSH 4.7p1 (released 2007) on the affected segment.	Multiple CVEs over 18 years. Combined with weak credential policy, this is a brute-force magnet.
P1-6	Integrate Suricata eve.json into Wazuh as a log source.	Brings network-layer detection into the unified SOC alert queue.

P2 - Medium term (1-3 months)

#	Recommendation	Rationale
P2-1	Implement an egress allowlist for internal servers. Block outbound HTTP/HTTPS to non-approved destinations by default.	This would have <i>prevented</i> the Caldera beacon entirely (P0-3 is mitigation; this is prevention).
P2-2	Configure auditd with execve and file-write monitoring on /etc/passwd, /etc/shadow, processes spawned by vsftpd, and processes with parent PID 1 that are not standard system services.	The backdoor shell forked by vsftpd would have been caught by execve auditing. The Caldera installation in /opt/caldera/ would have been caught by file-write auditing on /opt/.
P2-3	Disable unused services on internal servers: Telnet/23 (deprecated), externally-exposed MySQL/3306, phpMyAdmin if not actively used.	Reduces attack surface. Finding I6 catalogues 5 protocols enumerated by the attacker, only 1 was actually used (FTP).
P2-4	Enable log rotation with extended retention (90-180 days) and ship logs off-host in near-real-time.	Finding I10: the current configuration lost the logs covering this incident due to a VM reboot.
P2-5	Implement Wazuh File Integrity Monitoring (FIM) on /opt/, /usr/local/bin/, /etc/init.d/, /etc/systemd/system/.	Persistence-typical paths. Would have caught the Caldera Sandcat installation if it occurred during a monitored window.
P2-6	Establish a vulnerability scanning programme. Monthly Nessus/OpenVAS scans against the internal segment.	vsftpd 2.3.4 has been a Critical finding in every commercial scanner since 2011.

P3 - Ongoing maturity

#	Recommendation	Rationale
P3-1	Schedule annual penetration testing exercises. External red team engagement with full report and remediation tracking.	Validates that defensive controls actually catch what they're configured for.
P3-2	Implement a TLS metadata analysis capability (JA3/JA4 fingerprinting, certificate transparency monitoring).	Future Caldera-equivalent attacks will use HTTPS, defeating payload inspection. Metadata-based detection is the next layer.
P3-3	Document and rehearse an Incident Response runbook specifically for SIEM-detected brute-force escalations.	Finding I9: Wazuh did raise 4 high-severity alerts. The gap was not detection; it was the absence of a workflow to act on them.
P3-4	Threat intelligence integration: subscribe to MITRE ATT&CK Navigator updates, AbuseIPDB, Spamhaus DROP. Feed into firewall and SIEM.	Reactive detection augmented by proactive blocking of known-bad infrastructure.
P3-5	Security awareness for IT operations team: identifying suspicious outbound traffic, recognising IoCs, escalation procedures.	The 'unusual outbound connection' was noticed by the IT team but only flagged retrospectively. Faster escalation reduces dwell time.

Strategic posture: the fundamental issue

The fundamental observation from this engagement is that NexaCorp has **detection telemetry available** (Wazuh receives logs and correctly applies vendor rules) but **no detection engineering layer** translating those raw alerts into actionable intelligence. Adding a Suricata NIDS in the egress path, writing a small set of targeted exploit-signature rules, and configuring SIEM correlation rules tailored to the asset inventory would close this gap with modest effort. The seven rules delivered here are a starting point; sustained detection engineering practice is the long-term answer.

Risk Matrix

The following 5×5 risk matrix plots each finding by its CVSS-derived **Impact** (vertical axis) against its custom **Likelihood** score (horizontal axis). Findings in the upper-right quadrant (high impact, high likelihood) require the most urgent remediation.

Impact ↓ / Likelihood →	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)				I4	I1, I5
High (4)			I8	I3, I9	
Medium (3)		I7	I2		
Low (2)		I10	I6		
Very Low (1)					

Critical Risk	High Risk	Medium Risk	Low Risk
---------------	-----------	-------------	----------

Critical-risk findings (top-right quadrant): I1, I4, I5 - these three findings combine maximum impact (root-level compromise or full vulnerable service exposure) with very high likelihood (unauthenticated, network-reachable, no special tooling required). They must be remediated **before any other action**.

High-risk findings: I3 (exploitation event, addressed structurally by remediation of I1), I8 (post-exploitation indicator requiring further investigation), and I9 (insufficient SIEM detection coverage - the strategic deficiency that enabled this incident to remain unflagged).

MITRE ATT&CK Mapping

Each finding is mapped to one or more MITRE ATT&CK Enterprise techniques (v15) to align this assessment with industry-standard threat intelligence frameworks. This mapping enables downstream integration with SIEM detection rules, threat hunting playbooks, and red-team exercise planning.

Finding	Tactic	Technique ID	Technique Name
I1, I3	Initial Access	T1190	Exploit Public-Facing Application
I3	Initial Access	T1133	External Remote Services
I4	Execution	T1059.004	Command and Scripting Interpreter: Unix Shell
I4	Discovery	T1033	System Owner/User Discovery
I4	Discovery	T1082	System Information Discovery
I4	Discovery	T1087.001	Account Discovery: Local Account
I4	Discovery	T1083	File and Directory Discovery
I4	Discovery	T1016	System Network Configuration Discovery
I4, I6	Discovery	T1049	System Network Connections Discovery
I5	Command and Control	T1071.001	Application Layer Protocol: Web
I5	Command and Control	T1029	Scheduled Transfer
I5	Command and Control	T1102	Web Service
I5	Persistence	T1543.002	Systemd Service (suspected)
I2	Reconnaissance	T1595.002	Active Scanning: Vulnerability Scanning
I2	Reconnaissance	T1589	Gather Victim Identity Information
I2	Initial Access	T1078.003	Valid Accounts: Local Accounts
I6	Discovery	T1046	Network Service Discovery
I6	Reconnaissance	T1592.002	Gather Victim Host Information: Software
I7	Credential Access	T1110.001	Brute Force: Password Guessing
I7	Credential Access	T1110	Brute Force
I8	Privilege Escalation	T1548.003	Sudo and Sudo Caching (suspected)

Tools and Standards

A. Tools Used During the Engagement

The following tools were used to investigate, validate, and document the findings in this report. All operations were conducted in a controlled SOC lab environment; no automated red-team toolset was deployed against the target.

Category	Tool	Purpose
Network capture analysis	tshark / Wireshark	PCAP triage, TCP stream reconstruction, payload inspection
	tcpreplay	Offline PCAP replay for rule validation
	tcprewrite	MTU adjustment of PCAP before replay
SIEM analysis	Wazuh 4.x dashboard	Event query (DQL), CSV export, severity distribution
	Python (csv, collections)	Statistical analysis of 397 SIEM events
Detection engineering	Suricata 6.0.4	NIDS engine, rule authoring & validation
	Custom Suricata ruleset (R1-R7)	Authored for this engagement (SIDs 9000001-9000007)
Decoding & analysis	base64 (CLI)	Caldera beacon payload decoding
	jq	JSON parsing (Wazuh exports, Caldera beacons)
	grep / sed / awk	Log filtering and field extraction
Remote access	OpenSSH + Tailscale	Remote access to BeCode SOC workstation
Documentation	VS Code, Markdown	Note-taking, journal, report drafting

B. Standards and Frameworks Followed

This engagement was conducted in alignment with internationally recognized incident response and detection engineering frameworks to ensure methodological rigor, comparability with industry baselines, and consistency in finding classification and reporting.

Standard / Framework	Version	Application in This Report
NIST SP 800-61 Rev. 2	2012	Computer Security Incident Handling Guide - investigation methodology
NIST SP 800-86	2006	Integrating Forensic Techniques into Incident Response - evidence handling
NIST SP 800-94	2007	Guide to Intrusion Detection and Prevention Systems - NIDS deployment
SANS PICERL	-	Incident response phases (Preparation, Identification, Containment, Eradication, Recovery, Lessons)
MITRE ATT&CK Enterprise	v15	Technique mapping for findings and detection rules
CVSS - Common Vulnerability Scoring System	v3.1	Severity scoring (Base Metrics) for each finding
CWE - Common Weakness Enumeration	v4.16	Root-cause classification of each finding
Suricata rule syntax	6.0.4	Detection rule authoring (R1-R7)

Glossary and Acronyms

The following table defines the technical acronyms and terms used throughout this report.

Acronym	Full Name	Description
AFPacket	Async Packet Capture	Linux kernel packet capture interface used by Suricata
API	Application Programming Interface	Endpoints exposed for programmatic interaction
C2	Command and Control	Channel through which an attacker remotely controls compromised systems
Caldera	MITRE Caldera	Open-source adversary emulation framework by MITRE
CSV	Comma-Separated Values	Text-based tabular data format
CVE	Common Vulnerabilities and Exposures	Public catalogue of disclosed vulnerabilities
CVSS	Common Vulnerability Scoring System	Numerical severity scoring framework
CWE	Common Weakness Enumeration	Classification of software weaknesses
DQL	Discover Query Language	Wazuh / OpenSearch query syntax
EVE	Extensible Event Format	Suricata's enriched JSON event log
FIM	File Integrity Monitoring	Detection of unauthorized file changes
FTP	File Transfer Protocol	Network protocol for file transfer (legacy, cleartext)
HIDS	Host-based Intrusion Detection System	Detection running on the monitored host
HTTP	HyperText Transfer Protocol	Application-layer protocol for the web
IoC	Indicator of Compromise	Artifact pointing to malicious activity
IDS	Intrusion Detection System	Sensor that alerts on suspicious traffic
JSON	JavaScript Object Notation	Lightweight data-interchange format
MAC	Media Access Control	Layer-2 hardware identifier
MITRE ATT&CK	Adversarial Tactics, Techniques and Common Knowledge	Threat intelligence framework
MTU	Maximum Transmission Unit	Largest packet size on a network link
NIDS	Network Intrusion Detection System	Sensor placed on the network for traffic inspection
NIST	National Institute of Standards and Technology	U.S. agency publishing security standards
OUI	Organisationally Unique Identifier	First 24 bits of a MAC address identifying the vendor
PAM	Pluggable Authentication Modules	Linux authentication framework
PCAP	Packet Capture	File format storing captured network traffic
PICERL	Prep, Identification, Containment, Eradication, Recovery, Lessons	SANS incident response process
PoC	Proof of Concept	Demonstration that a vulnerability is exploitable
RCE	Remote Code Execution	Vulnerability allowing arbitrary code execution remotely
RFC1918	Private IPv4 Address Space	10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16
Sandcat	-	MITRE Caldera's default cross-platform implant
SCP	Secure Copy Protocol	File transfer over SSH
SFTP	SSH File Transfer Protocol	Secure replacement for FTP
SID	Signature Identifier	Unique numeric ID of a Suricata or Snort rule
SIEM	Security Information and Event Management	Log aggregation and correlation platform
SOC	Security Operations Center	Team responsible for security monitoring and response
SSH	Secure Shell	Encrypted remote-administration protocol
SYN	Synchronize	TCP flag initiating a connection (3-way handshake)
TCP	Transmission Control Protocol	Connection-oriented transport-layer protocol
TLS	Transport Layer Security	Cryptographic protocol securing network communications
TTPs	Tactics, Techniques and Procedures	Behaviour-level attacker characterisation
UA	User-Agent	HTTP header identifying the client software
URI	Uniform Resource Identifier	String identifying a resource
UTC	Coordinated Universal Time	Time reference used throughout this report
vsftpd	Very Secure FTP Daemon	FTP server implementation for Unix-like systems
Wazuh	-	Open-source SIEM and HIDS platform

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026

Classification: Internal - Not for distribution

Analyst

Johan-Emmanuel Hatchi

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi